Programa:	Auto Backup 2.4	
Protección:	Packed / Cinderella	
Objetivos:	Desempaquetar el archivo y eliminar el Time-Trial	
URL descarga:	---	
Dificultad:	No es difícil	
Herramientas:	OllyDbg, PeiD, Import Reconstructor, LordPE y w32dasm	
Cracker:	SyXe'05 [hAcK-c0d3d]	Fecha: 26-07-2005

Programa para hacer backups de los archivos (copias de seguridad) está comprimido con UPX, este compresor no plantea dificultad alguna pero este en concreto tiene alguna mejora que no deja correr la aplicación porque nos cuelga el Olly, el tema está como más adelante veremos en una división por 0 que genera una excepción, veamos de momento los datos más significativos del programa:

Packer: UPX 0.89.6 - 1.02 / 1.05 - 1.24 (Delphi) stub -> Markus & Laszlo [Overlay] **/*según PEiD*/**
OEP: 5901f0
IAT => Inicio: 59e1e0
Final: 59eba8
Largo: 9c8

Ya desempaquetado el archivo (dumpeado con LordPE e intelliidump activado) no corre todavía, el motivo está en que el muy cabroncete nos genera una excecpción del tipo "INTEGER_DIVIDED_BY_ZERO" que hace que se aborte la ejecución, para solventar esto topamos la instrucción conflictiva que es esta …

```
:0049A680   E8 9FAEF6FF     CALL dump_pru.00405524
:0049A685   50              PUSH EAX
:0049A686   8BC3            MOV EAX,EBX
:0049A688   5A              POP EDX
:0049A689   8BCA            MOV ECX,EDX
:0049A68B   99              CDQ
:0049A68C   F7F9            IDIV ECX        <= Ojo a esto...!!!
:0049A68E   8B45 F8         MOV EAX,DWORD PTR SS:[EBP-8]
```

En este momento veamos los registros:

Ahí está ECX=0!!! Está intentando dividir entre 0, esto provocará una excepción que nos dejará muertos, solventemos el problema:

Instrucción conflictiva: 0049A68C F7F9 IDIV ECX

Cambiemos:

```
:0049A68C   F7F9        IDIV ECX        POR:
:0049A68C   9090        NOP'S
```

Con esto decimos adiós al truquito barato, ya podemos continuar, ahora debemos ocuparnos de la nag de Expired que aparece cuando queremos entrar en el programa, esto se hace como siempre traceamos con Olly en busca de la zona peligrosa, en este caso esta:

```
:005915AF   80B8 68020000 00   CMP BYTE PTR DS:[EAX+268],0      ;Estamos registrados?
:005915B6   75 3B              JNZ SHORT ABackup.005915F3       ;si => saltamos por encima de la nag.
:005915B8   A1 A8AC5900        MOV EAX,DWORD PTR DS:[59ACA8]
:005915BD   8B00               MOV EAX,DWORD PTR DS:[EAX]
:005915BF   83B8 60020000 00   CMP DWORD PTR DS:[EAX+260],0      ;Ha expirado el programa?
```

```
:005915C6   75 2B          JNZ SHORT ABackup.005915F3      ;no => saltamos por encima de la nag.
:005915C8   6A 00          PUSH 0
:005915CA   6A 00          PUSH 0
:005915CC   33C9           XOR ECX,ECX
:005915CE   B2 01          MOV DL,1
:005915D0   B0 01          MOV AL,1
:005915D2   E8 8927FFFF    CALL ABackup.00583D60           ;Call que pinta la nag en pantalla..!!
```

Tenemos que:

[D16048] -> Contador de dias restantes
[D16048] -> Flag de registro (a medias)

un parche podría ser por ejemplo cambiar:

```
:005915AF   80B8 68020000 00   CMP BYTE PTR DS:[EAX+268],0
:005915B6   75 3B              JNZ SHORT ABackup.005915F3
```

POR:

```
:005915AF   C680 68020000 01   MOV BYTE PTR DS:[EAX+268],1
:005915B6   EB 3B              JMP SHORT ABackup.005915F3
```

Ahora nos aparece una ventanita al poco de tener el programa abierto, busquémosla “BP ShowWindow” en el CommandBar y rompemos en la API, retornamos a:

```
:0048CD74   E8 67BCF7FF    CALL <JMP.&user32.ShowWindow>
:0048CD79   33C0           XOR EAX, EAX
```

sigamos traceando hasta que aparezca la ventana en pantalla, antes deshabitemos el breakpoint desde el propio CommandBar también mediante “bc ShowWindow” y continuemos a lo nuestro, llegaremos a:

En la ventanita About vemos UNREGISTERED, si miramos entre las strings la encontramos en esta zona:

```
:00584637   E8 600CE8FF    CALL ABackup.0040529C
:0058463C   68 78495800    PUSH ABackup.00584978          ; ASCII "UNREGISTERED!"
:00584641   8D85 B4FEFFFF  LEA EAX,DWORD PTR SS:[EBP-14C]
```

Estas líneas forman parte de una rutina, así que pongamos un BPX sobre la cadena a seguir picamos en About y Olly saltará ahora retornemos hasta donde se hizo la llamada:

```
:00489905   66:83B8 CA02000>  CMP WORD PTR DS:[EAX+2CA],0     ;bonito flag!
:0048990D   74 10             JE SHORT ABackup.0048991F       ;y luego el salto
:0048990F   8BD8              MOV EBX,EAX
:00489911   8BD0              MOV EDX,EAX
:00489913   8B83 CC020000     MOV EAX,DWORD PTR DS:[EBX+2CC]
:00489919   FF93 C8020000     CALL DWORD PTR DS:[EBX+2C8]     ;About_Unregistered!
```

La llamada se hizo desde :489919, si cambiamos el salto o modificamos el flag sale la ventana con la leyenda ‘Registered to:’ y no aparece el UNREGISTERED al lado como antes pero tampoco aparece la imagen que debe ir al lado, estamos cerca pero aún falta un poco, hilando más fino llegamos a un subcall de este a ver que podemos hacer, sigamos investigando:

```
:004979B8   66:837D 12 00   CMP WORD PTR SS:[EBP+12],0       ;Bonito flag!
:004979BD   74 18           JE SHORT ABackup.004979D7       ;Y aqui el salto..
:004979BF   8B45 F4         MOV EAX,DWORD PTR SS:[EBP-C]
:004979C2   50              PUSH EAX
:004979C3   8B45 F0         MOV EAX,DWORD PTR SS:[EBP-10]
:004979C6   50              PUSH EAX
:004979C7   8B45 EC         MOV EAX,DWORD PTR SS:[EBP-14]
:004979CA   50              PUSH EAX
:004979CB   8B4D F8         MOV ECX,DWORD PTR SS:[EBP-8]
:004979CE   8B55 FC         MOV EDX,DWORD PTR SS:[EBP-4]
```

```
:004979D1   8B45 14          MOV EAX,DWORD PTR SS:[EBP+14]
:004979D4   FF55 10          CALL DWORD PTR SS:[EBP+10]        ;Call del About
:004979D7   33C0             XOR EAX, EAX
```

Aquí vemos que esta es otra zona pero es un subcall del anterior a ver si podemos modificar algún flag y que nos ayude un poco, jeje.. pues mirando vemos que la nag aparece en :4979d4 y que hay un salto que pasa por encima y es controlado por [EBP+12] que representa [12ecda] y vale A1380058 mirad que está verificando el byte bajo, o sea el 58 y lo compara con 0, si ponemos el flag a 0 para que así salte ahora si vemos la nag en condiciones con la imagen y todo, quedo ahí el botón Register sin etiqueta lo que quiere decir que podemos hilar todavía mas fino y luego además no pone nuestro nombre cosa que luego abordaremos, yo os digo que voy escribiendo el tuto a la vez que lo intento resolver pues es como me gusta mas hacerlos pues sale la cosa mas real ;DDD

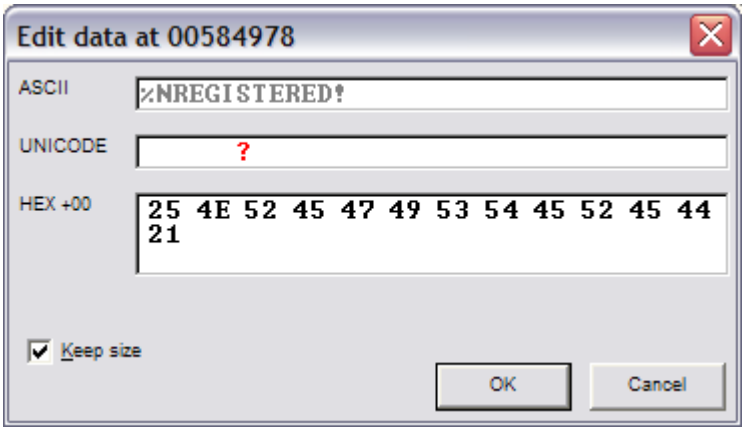
Otra solución también válida sería ir a la zona del push donde se le pasa la cadena UNREGISTERED y cambiarla por nuestro nombre, os explico como hacerlo, volvamos a esta zona:

```
:0058463C   68 78495800      PUSH ABackup.00584978          ; ASCII "UNREGISTERED!"
:00584641   8D85 B4FEFFFF    LEA EAX,DWORD PTR SS:[EBP-14C]
```

Allí vemos la cadena, nos situamos justo encima de la instrucción picamos con el botón derecho y elegimos “Follow in dump / Inmediate constant” caeremos en esta parte mirando al stack:

```
Address   Hex dump                                          ASCII
00584978  55 4E 52 45 47 49 53 54 45 52 45 44 21 00 00 00  UNREGISTERED!...
00584988  FF FF FF FF 17 00 00 00 6C 61 62 52 65 67 55 73      ‡...labRegUs
00584998  65 72 56 61 6C 75 65 2E 43 61 70 74 69 6F 6E 00  erValue.Caption.
005849A8  FF FF FF FF 2F 00 00 00 59 6F 75 20 68 61 76 65      /...You have
005849B8  20 25 31 3A 64 20 64 61 79 73 20 72 65 6D 61 69   %1:d days remai
005849C8  6E 69 6E 67 20 28 54 6F 74 61 6C 20 25 30 3A 64  ning (Total %0:d
005849D8  20 64 61 79 73 29 2E 00 FF FF FF FF 13 00 00 00   days)..    ‼...
```

Allí vemos la cadena ;DDD que tal si la seleccionamos y cambiamos lo que pone por lo que queramos, cada uno obviamente debe poner su nombre para que quede bien, o sea que cada uno lo acomode a su caso particular, para este caso la cambiaremos por la cadena "[hAcK-c0d3d]!" nos situamos sobre la cadena y la seleccionamos automáticamente comenzamos a escribir ojo no con letras de momento algún digito hexadecimal, el que sea ya lo cambiaremos esto es para que se abra este cuadro:



Ahí vemos como yo pulse el “2” y sobrescribió el “5” que allí había y el primer digito quedo cambiado, no importa, situemos el cursor en la parte donde dice ASCII y cambiemos el texto por lo que queramos aceptamos y:

```
Address   Hex dump                                          ASCII
00584978  5B 68 41 63 4B 2D 63 30 64 33 64 5D 21 00 00 00  [hAcK-c0d3d]!...
00584988  FF FF FF FF 17 00 00 00 6C 61 62 52 65 67 55 73      ‡...labRegUs
00584998  65 72 56 61 6C 75 65 2E 43 61 70 74 69 6F 6E 00  erValue.Caption.
005849A8  FF FF FF FF 2F 00 00 00 59 6F 75 20 68 61 76 65      /...You have
005849B8  20 25 31 3A 64 20 64 61 79 73 20 72 65 6D 61 69   %1:d days remai
005849C8  6E 69 6E 67 20 28 54 6F 74 61 6C 20 25 30 3A 64  ning (Total %0:d
005849D8  20 64 61 79 73 29 2E 00 FF FF FF FF 13 00 00 00   days)..    ‼...
```

Así deberá quedar, cada uno como digo que ponga su nombre, ahora en el código se vera esto:

```
:0058463C  68 78495800       PUSH ABackup.00584978          ;  ASCII "[hAcK-c0d3d]!"
:00584641  8D85 B4FEFFFF     LEA EAX,DWORD PTR SS:[EBP-14C]
```

jeje.. está pusheando nuestro nombre que es el que aparecerá en el About, podemos hacer lo mismo para la cadena “You have x days bla bla bla…” que se ve justo debajo, aquí incluso podríamos cambiar el primer carácter cuyo código ASCII es “59" por “00” que significa fin de cadena (NULL) así creerá que escribió todos los caracteres ya cuando en realidad no escribió ninguno. Bueno ya os digo que esta no es la mejor opción que tenemos porque siempre vale mas la pena modificar algún flag, call, etc.. que nos haga el trabajito por nosotros y mas limpiamente encima pero bueno tampoco esta mal del todo eso es verdad cada uno lo hace como bien puede, hacemos los cambios vamos al About y…

¿Qué pasa aquí? La cadena sigue saliendo aun habiendo la cambiado nosotros, no hace falta decir que la obtiene de otra parte y que esta es un simple señuelo, jeje… que cabroncetes nos quieren hacer trabajar mas aun, veamos si miramos a la pila estando en esta misma rutina veremos que aparece la cadena UNREG... después de pasar sobre el siguiente call:

:00584677 FF17 CALL DWORD PTR DS:[EDI] **;Aquí nos pone la cadena**

dentro del call toma la cadena justo aquí:

:004434DF 8D95 00F8FFFF LEA EDX,DWORD PTR SS:[EBP-800] **;en EDX la cadena**
:004434E5 8B45 08 MOV EAX,DWORD PTR SS:[EBP+8]

[EBP-800] tiene la culpa representa [12E19C] y tiene la cadena buscada, si miramos por encima vemos esta llamada a la API “GetPrivateProfileStringA” que se utiliza mayormente para obtener información de algún archivo generalmente *.ini, asi que el amigo esta leyendo de un archivo la cadena ;DDD esto se pone cada vez mas interesante, vamos al CommandBar y pongamos “BP GetPrivateProfileStringA” y le damos a f9 para dejarlo correr vamos al About y Olly romperá donde queremos

```
0012E174  004434DD  CALL to GetPrivateProfileStringA from ABackup.004434D8
0012E178  00CA1398  Section = "TfrmRegs"
0012E17C  005849E8  Key = "labTrialDay.Caption"
0012E180  005849B0  Default = "You have %1:d days remaining (Total %0:d days)."
0012E184  0012E19C  ReturnBuffer = 0012E19C
0012E188  00000800  BufSize = 800 (2048.)
0012E18C  00C88DCC  IniFileName = "C:\Archivos de programa\Auto Backup 2.4\Languages\English.lng"
0012E190  00442B08  ASCII "ÿ4D"
```

Ahí estça la llamada, no se porque se ve algo borrosa pero creo que se ve claro que retornaremos a :4434dd y que la llamada se realizo desde :4434d8, vamos para allá, ah! Además vemos el nombre del archivo “English.lng” al

que quiere acceder y su ubicación, ctrl.+f9 para que se ejecute la función y lleguemos a :4434dd, pero antes miremos un poco el archivo sobretodo la parte [TfrmRegs]:

```
[TfrmRegs]
.Caption =About %0:s %1:s
.Caption_0 =Register %0:s %1:s
labBuild.Caption =Build:
labAuthor.Caption =Author:
labTranslator.Caption =Translator:
labMail.Caption =E-mail:
labHome.Caption =Home:
labRegUser.Caption =Registered to:
labLicense.Caption =License type:
labCopyright.Caption =Copyright (c) 2001, 2005 Han-soft software
labCaption.Caption =Auto Backup
labVersion.Caption =Version 2.4
labReg1.Caption =1. Press the "Buy now" button to visit our site and get your license key.
labReg2.Caption =2. If you have got a license key, please fill out the following form, then press the "Register" button.
grpRegInf.Caption =Registration information
labUserName.Caption =&User name:
labUserMail.Caption =User e-&mail:
labLicenseKey.Caption =License &key
btnBuyNow.Caption =1. &Buy now
btnPaste.Caption =&Paste from clipboard
btnRegister.Caption =2. &Register
btnRegister.Caption_0 =De&register
btnOK.Caption =&Close
labCaption.Font.Name =Impact
labCaption.Font.Size =22
labCaption.Font.Charset =1
btnHelp.Caption =&Register
btnHelp.Caption_0 =&How to buy
btnHelp.Caption_1 =User &information
labRegUserValue.Caption =UNREGISTERED!
labTrialDay.Caption =You have %1:d days remaining (Total %0:d days).
DeregisterService =For non-site license, the service will be uninstalled, please run the Auto Backup as an normal application.
```

Allí están los datos que lee, si le cambiamos los siguientes datos:

```
labRegUserValue.Caption =UNREGISTERED!
labTrialDay.Caption =You have %1:d days remaining (Total %0:d days).
```

POR:

```
labRegUserValue.Caption =[hAck=c0d3d]!
labTrialDay.Caption =
```

ahora la nag tendrá este aspecto:

Ahora si conseguimos nuestro objetivo ya no aparece el mensaje que el quiere sino nuestro nombre, no estoy seguro pero imagino que modificando bien este archivo conseguiremos quedar registrados aunque como digo es una suposición nada más.

Pero se guarda un AS en la manga porque estando utilizando el programa con total normalidad de repente nos aparece el cuadro de registro de golpe en pantalla e interrumpe lo que estemos haciendo, además si no le ponemos el código valido nos cierra la aplicación, este es el cuadro:

No lo he contabilizado pero creo que sale en un tiempo aleatorio asi que el “SetTimer” no creo que nos pueda ayudar mucho, pero si el resto de API’s de Windows, probaremos con ShowWindow teniendo el programa abierto

en Olly para que rompa y nos pase el control antes de que la saque por pantalla a ver si la podemos sortear y que no salga más, veamos vamos al CommandBar y ponemos “Bp ShowWindow” como hicimos antes pero ahora investigaremos más profundamente esta línea de ataque ;DDDD

Olly romperá aqui:

```
:0048CD73   50              PUSH EAX
:0048CD74   E8 67BCF7FF     CALL <JMP.&user32.ShowWindow>
```

vayamos traceando a lo retro tras varios retornos llegaremos a:

```
:004050F7   833D 04305900 0>  CMP DWORD PTR DS:[593004],0     ;bonito flag..!!
:004050FE   74 11             JE SHORT ABackup.00405111       ;salto que evita el call peligroso
:00405100   E8 AFFEFFFF       CALL ABackup.00404FB4
:00405105   E8 36FFFFFF       CALL ABackup.00405040           ;call malo
```

Finalmente traceando un poquito más llegamos a:

```
:0040518E   50              PUSH EAX
:0040518F   E8 64C1FFFF     CALL <JMP.&kernel32.ExitProcess>
```

Esta linea no me llevo a nada interesante salvo esto:

```
:00490819   80B8 9C000000 0>  CMP BYTE PTR DS:[EAX+9C],0
:00490820   74 BF             JE SHORT ABackup.004907E1
```

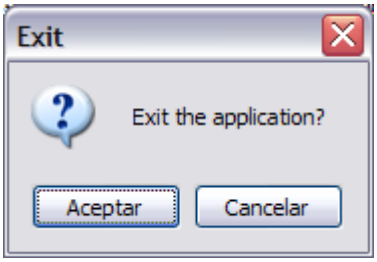
Este salto mantiene al programa en pantalla, mientras [EAX+9C] valga lo que sea mientras que no sea 0 estará en pantalla, entonces como nos cierra la ejecución está claro que le debe poner un 0 antes para que aquí no salte y así echarnos a la calle, vemos que [EAX+9C] representa [C71774] reiniciemos ponemos un BPX en :490820 luego un BPHW (tamaño byte que es el que verifica realmente) en el flag a ver donde lo pone a 0, rompemos en:

```
:00490592   C686 9C000000 0>  MOV BYTE PTR DS:[ESI+9C],1  => Nos va a echar ya...!!!
:00490599   8BC3              MOV EAX, EBX
```

Si cambiamos:

```
:00490592   C686 9C000000 01  MOV BYTE PTR DS:[ESI+9C],1    POR:
:00490592   C686 9C000000 00  MOV BYTE PTR DS:[ESI+9C],0
```

Ya no cierra la aplicación pero tampoco nosotros podremos cerrarla a no ser que injertemos código o algo que se nos ocurra para que distinga cuando quiere cerrarse por este problema o cuando queremos cerrar nosotros, nos beneficiaremos de este mensaje:



Buscaremos el momento exacto en que saca el mensajito y en caso de decir que SI realizamos un salto a una zona libre del ejecutable que parchee el flag de manera que podamos salir, el parche será algo así:

```
MOV BYTE PTR [00490598], 01     ;Restauramos el flag
[Ejecutrar instrucciones sobrescritas]  ;y ejecutamos lo que hemos sobrescrito para poner el salto
jmp programa
```

Busquemos una zona libre, tenemos una a partir de :59B100

Ahora busquemos el mensaje anterior, break en la API MessageBoxA y cuando pare miramos la pila:

```
0012FA1C  004909D7  CALL to MessageBoxA from ABackup2.004909D2
0012FA20  00940238  hOwner = 00940238 ('Auto Backup 2.4',class='TApplication')
0012FA24  00C82ED4  Text = "Exit the application?"
0012FA28  00C93434  Title = "Exit"
0012FA2C  00000021  Style = MB_OKCANCEL|MB_ICONQUESTION|MB_APPLMODAL
0012FA30  0012FAA8  Pointer to next SEH record
0012FA34  00490A41  SE handler
```

Allí está la llamada se realizó desde :4909D2 y retornaremos a :4909D7 vayamos allí a ver qué tenemos:

```
:004909D2   E8 317EF7FF        CALL <JMP.&user32.MessageBoxA>
:004909D7   8945 F8            MOV DWORD PTR SS:[EBP-8],EAX      <= Mira que botón hemos pulsado
```

Allí está la llamada, a la salida tenemos EAX=1 ya que pulse que SI quería salir, sigamos hasta el siguiente retorno, salimos en esta otra parte:

```
:00589C6D   E8 7A6CF0FF        CALL ABackup2.004908EC        ;De aquí venimos..!!
:00589C72   48                 DEC EAX
:00589C73   0F85 D6000000      JNZ ABackup2.00589D4F         ;Salta si elegimos NO
:00589C79   8B83 A8030000      MOV EAX,DWORD PTR DS:[EBX+3A8]
```

Pues aqui creo que podemos injertar ya, llegaremos a :589C79 en caso de que queramos salir entonces ahora entra en juego el injerto, en lugar de la instrucción:

```
:00589C79   > \8B83 A8030000   MOV EAX,DWORD PTR DS:[EBX+3A8]
```

pondremos:

```
:00589C79   E9 82140100        JMP ABackup2.0059B100         ;Vamos al injerto..!!
:00589C7E   90                 NOP
```

En :59B100 escribimos estas líneas:

```
0059B100   C605 98054900 01   MOV BYTE PTR DS:[490598],1          ;parcheamos el flag
0059B107   8B83 A8030000      MOV EAX,DWORD PTR DS:[EBX+3A8]     ;ejecutamos la instrucción sobrescrita
0059B10D   E9 6DEBFEFF        JMP ABackup2.00589C7F              ;y retornamos al código…
```

Pues bueno injertamos, seleccionamos los bytes escritos y salvamos los cambios con"Save All" ya que hicimos varios parches el salto y luego estos bytes si ponemos "Save Selection" solo salvara los bytes seleccionados y no todos como queremos, podemos probar el injerto que veremos funciona, hace bien su trabajo, ahora solo queda matar la nag que aparece de vez en cuando, como desde Olly es difícil de abordar ya que cuando estamos depurando el proceso la nag no sale o almenos en mi caso, rastrearemos el flag de registro que antes hemos modificado a ver donde toma los valores y evitar que se ponga a 0, el flag era [C74CBC] y recordemos debe estar a 1, pongamos un HBPW dword en el y reiniciemos, Olly romperá por primera vez aquí:

```
:00404336   F3:AB              REP STOS DWORD PTR ES:[EDI]       /*nada ni caso, sigamos... F9
:004B95A5   C683 68020000 00   MOV BYTE PTR DS:[EBX+268],0       /*debemos evitarlo, luego veremos... F9
:004BA752   C680 68020000 00   MOV BYTE PTR DS:[EAX+268],0       /*igual que antes…
:004BA562   C680 68020000 00   MOV BYTE PTR DS:[EAX+268],0       /*ídem...
:005915AF   C680 68020000 00   MOV BYTE PTR DS:[EAX+268],1       /*aquí ya hemos parcheado  antes ;DDDD
```

Con esta información intentaremos hacer algo, de momento probamos a ir dejando un 1 en el flag desde el inicio y tiene muy buena pinta pues en el About nos dice que estamos licenciados (registrados), ahora intentemos hacer los cambios permanentes desde el mismo Olly parcheamos todas las asignaciones para que el flag pille un 1, p.ej:

```
:004B95A5   C683 68020000 00   MOV BYTE PTR DS:[EBX+268],0       POR:
:004B95A5   C683 68020000 01   MOV BYTE PTR DS:[EBX+268],1
```

el resto las podemos nopear para que continúe con el 1 hasta el final a ver que ocurre… pues parece que FUNCIONA!!! Estamos un rato con el programa abierto en pantalla, ahora el botón “Register” se ha convertido en “User Information” allí debería estar nuestro nombre pero no aparece, esto es el único pero de este crack.

Y hasta aquí hemos llegado por hay, otro día seguiremos abordando programas de este estilo que hay muchísimos mas por ahí, si alguien quiere hacer cualquier tipo de comentario, duda, sugerencia o critica que lo haga en:

syxe00@yahoo.es
syxe00@hotmail.com

Por descontado decir que serán contestados todos y cada uno de los mensajes recibidos.